

Firewall Manager and IoT Core

Applying protection across every account, including the ones created next week – and securing devices that hold no AWS credentials.

Firewall Manager's product is not protection. It is **protection that does not drift.**

What Firewall Manager needs before it works

- ◆ **AWS Organizations with all features**, and a designated **Firewall Manager administrator account**.
- ◆ **AWS Config must be enabled** in every in-scope account and Region. FMS creates Config rules to detect drift.
- ◆ **RAM resource sharing** for Network Firewall and DNS Firewall policies.
- ◆ New accounts come into scope **automatically**. That is the whole point.
- ◆ Scope by account, OU or **resource tag** – tags carve out exceptions without disabling the policy.

ON THE EXAM

No configuration recorder, no drift detection. The module 4 dependency again.

The policy types

POLICY	APPLIES
AWS WAF	A web ACL to ALBs, API Gateway, CloudFront and more
Shield Advanced	Shield Advanced protections to in-scope resources
Security groups	Three kinds: common baseline, content audit, usage audit
Network ACL	Enforces a baseline set of first and last NACL rules
Network Firewall	Firewalls into your organisation's VPCs
DNS Firewall	Route 53 Resolver DNS Firewall rule groups to VPCs
Third-party firewall	Palo Alto Cloud NGFW, Fortigate CNF, via Marketplace

ON THE EXAM

Seven families. The security group one splits three ways, and that split is the most likely thing to be tested.

The three security group policies

- ◆ **Common** – applies a baseline group to in-scope resources.
- ◆ **Content audit** – inspects the **rules inside** existing groups against a template, and can auto-remediate.
- ◆ **Usage audit** – finds **unused or redundant** groups and can delete them.
- ◆ Content audit answers 'nobody may open port 22 to 0.0.0.0/0 anywhere'.
- ◆ Firewall Manager **detects and remediates**. An SCP **prevents**.

ON THE EXAM

Common applies a group. Content audit polices other groups. Usage audit deletes unused ones.

Firewall Manager: the honest version

- ◆ **Firewall Manager does not support Amazon Route 53 or AWS Global Accelerator.** You cannot apply Shield Advanced to those with a policy.
- ◆ Those resources must be protected **directly in Shield Advanced**, per account, and kept in step by hand.
- ◆ It is **reactive**. A resource can exist unprotected between creation and the next evaluation.
- ◆ It creates **Config rules per policy per account**, so both the policy and those rules appear on your bill.
- ◆ Remediation can be automatic or manual. Automatic on a content audit policy will change other teams' security groups.

ON THE EXAM

A documented exception, and exactly what a specialty exam asks about.

IoT Core: how a device proves who it is

- ◆ **X.509 client certificates with TLS mutual authentication.** A certificate, not an access key.
- ◆ **One unique certificate per device,** or you cannot revoke one without revoking the fleet.
- ◆ Register your own CA, or use **just-in-time** and **fleet provisioning** so devices enrol at first connection.
- ◆ **Custom authorizers** cover bearer tokens when certificates are impractical.
- ◆ AWS-generated certificates expire **31 December 2049**. Devices must still support rotation.

ON THE EXAM

The design point: a device stores a certificate you can revoke individually, never a credential.

IoT Core: what a device is allowed to do

- ◆ **AWS IoT Core policies** are JSON, follow IAM conventions, and attach to a **certificate**, a **Cognito identity**, or a **thing group**.
- ◆ Same evaluation logic as IAM: **implicit deny by default**, and an **explicit deny always wins**.
- ◆ For a policy attached to a thing group to take effect, the **clientId must match the thing name**.
- ◆ **Thing policy variables** like `iot:Connection.Thing.ThingName` let one policy serve a whole fleet while scoping each device to its own topic.
- ◆ **Certificate policy variables** are powerful and fragile: if the certificate lacks the attribute, evaluation behaves unexpectedly.

ON THE EXAM

One policy plus a thing policy variable is how you avoid writing 50,000 policies. It is ABAC, arriving early and in disguise.

When a device needs to call other AWS services

- ◆ Other AWS services do not accept X.509 certificates. They want SigV4-signed requests.
- ◆ The **IoT Core credential provider** exchanges the certificate for **temporary, limited-privilege credentials**.
- ◆ Create an **IAM role** and a **role alias**; the provider assumes the role for the device.
- ◆ No access key ever reaches the device. The answer whenever devices write to S3 or Kinesis.
- ◆ `credentials-iot:ThingName` works in **IAM policies only**, not IoT Core policies.

ON THE EXAM

Device Defender audits the rest: shared certificates, expiry, over-permissive policies.

A retailer has 200 accounts. A standard web ACL is supposed to be attached to every internet-facing Application Load Balancer. An audit finds 34 load balancers with no web ACL: some in accounts created after the original rollout, and some where an engineer disassociated the ACL while debugging and never reattached it.

The security team wants every current and future ALB covered, with drift corrected automatically and without asking account owners to do anything.

What should the retailer implement?

- ☐ A CloudFormation StackSet with automatic deployment attaching the web ACL in every account
- ☐ An AWS Firewall Manager WAF policy scoped to the organisation, with automatic remediation
- ☐ An SCP denying wafv2:DisassociateWebACL across the organisation
- ☐ A Config rule checking for web ACL association, with an SNS notification to account owners

◆ PAUSE AND DECIDE

What should the retailer implement?

A StackSet with automatic deployment

Covers new accounts and does not correct drift. A StackSet deploys; it does not continuously reconcile a manual disassociation.

C SCP denying wafv2:DisassociateWebACL

Stops the second cause and not the first: the accounts that never had a web ACL still do not. Preventive controls do not fix an existing gap.

B Firewall Manager WAF policy with automatic remediation

Correct. Continuous evaluation across the organisation, automatic reattachment when someone disassociates, and new accounts brought into scope on their own.

D Config rule with SNS notification

Detects and tells someone. The requirement says without asking account owners to do anything, which rules out any answer ending in a notification.

THE SIGNAL

Two causes – never applied, and applied then removed – and only a continuously reconciling control addresses both.

A gaming company uses Firewall Manager to apply Shield Advanced across its organisation. The policy successfully covers Application Load Balancers, Elastic IPs and CloudFront distributions in all 60 accounts.

The company also runs Route 53 hosted zones and AWS Global Accelerator standard accelerators, both of which are supported Shield Advanced resource types. Neither appears as protected, and adding them to the Firewall Manager policy scope has no effect.

Why are those resources unprotected?

- ☐ A Route 53 and Global Accelerator require Shield Advanced to be enabled in us-east-1 first
- ☐ B Global resources need a separate Firewall Manager policy with CloudFront scope
- ☐ C Those resource types require a Route 53 health check before Shield Advanced will protect them
- ☐ D Firewall Manager does not support Route 53 or Global Accelerator; protect them directly in Shield Advanced

◆ PAUSE AND DECIDE

Why are those resources unprotected?

- A

 Shield Advanced must be enabled in us-east-1 first
Plausible-sounding and invented. The scenario also shows CloudFront distributions already protected by the same policy, so global scope is clearly working.
- B

 A separate policy with CloudFront scope
There is no such policy scope in Firewall Manager, and CloudFront distributions are already covered by the existing policy.
- C

 They need a Route 53 health check first
Health checks enable health-based detection and proactive engagement, from module 8. They are not a precondition for protection.
- D

 Firewall Manager does not support these; protect them directly
Correct. AWS documents this exception explicitly. These two resource types must be added to Shield Advanced per account, outside Firewall Manager.

THE SIGNAL

Adding them to scope had no effect and raised no error. Silent non-support is the tell for a documented service exception.

A manufacturer has 50,000 sensors connecting to AWS IoT Core. To simplify manufacturing, every device was flashed with the same X.509 certificate and the same IoT Core policy, which permits publishing to any topic under factory/.

One device is physically stolen from a depot. The security team wants to stop that device connecting, without interrupting the other 49,999, and wants each device restricted to its own topic in future.

What should the manufacturer do?

- ☐ A Issue a unique certificate per device, and scope one policy using thing policy variables
- ☐ B Revoke the shared certificate and reissue it to the remaining devices over the air
- ☐ C Write 50,000 IoT Core policies, one per device, attached to the shared certificate
- ☐ D Attach an IAM policy to the shared certificate denying the stolen device's client ID

◆ PAUSE AND DECIDE

What should the manufacturer do?

- A** Unique certificate per device, one policy with thing policy variables
Correct. Unique certificates make individual revocation possible, and a thing policy variable scopes each device to its own topic without writing 50,000 policies.
- B** Revoke and reissue the shared certificate
Revoking disconnects all 50,000 at once, and reissuing the same shared certificate recreates the identical problem for the next theft.
- C** 50,000 policies on the shared certificate
Policies attach to a certificate, so 50,000 policies on one certificate cannot distinguish between devices presenting it. Unmanageable and ineffective.
- D** IAM policy on the certificate denying a client ID
IoT Core policies attach to certificates; IAM policies attach to IAM principals. And a stolen device can simply present a different client ID.

THE SIGNAL

A shared certificate makes revocation an all-or-nothing act. That is the whole reason AWS recommends one per device.

A logistics company's vehicle trackers publish telemetry to IoT Core. A new requirement has each device upload a daily diagnostic file directly to an S3 bucket, rather than routing it through an IoT rule.

A developer proposes embedding an IAM access key and secret in the device firmware. The security architect rejects this and is asked for an alternative that keeps devices free of long-lived credentials.

What should the architect propose?

- ☐ A An IoT rule that forwards the file content to a Lambda function which writes to S3
- ☐ B A Cognito identity pool issuing credentials to each device on connection
- ☐ C The AWS IoT Core credential provider with a role alias, using the device's X.509 certificate
- ☐ D Presigned S3 URLs generated daily and pushed to each device over MQTT

◆ PAUSE AND DECIDE

What should the architect propose?

- A

 IoT rule forwarding to Lambda
The scenario explicitly says directly to S3 rather than through an IoT rule. It also puts a message-size ceiling in front of a diagnostic file.
- B

 Cognito identity pool per device
Cognito issues AWS credentials to application users. These devices already hold a strong identity - a certificate - and Cognito adds a second identity system to run.
- C

 IoT Core credential provider with a role alias
Correct. It exchanges the existing X.509 certificate for temporary, limited-privilege credentials, so no long-lived key ever reaches the device.
- D

 Presigned URLs pushed over MQTT
Workable and it builds a distribution system with expiring URLs to manage, and a device that cannot upload if it missed the message.

THE SIGNAL

The device already has an identity. The credential provider turns that identity into AWS credentials, which is exactly the gap.

Five things to carry forward

- ◆ **Firewall Manager is for drift.** Inconsistent across accounts, or new accounts missed, is its signature.
- ◆ **It needs AWS Config,** and it **does not support Route 53 or Global Accelerator.**
- ◆ **Content audit polices the rules inside other teams' security groups.** Common applies one; usage audit deletes unused ones.
- ◆ **One certificate per IoT device,** so revocation is not all-or-nothing.
- ◆ **The IoT credential provider with a role alias** is how a device calls other AWS services without storing a key.

ON THE EXAM

Next: network controls – security groups, network ACLs, Network Firewall and DNS Firewall.